

STANDARD OPERATING PROCEDURE

SOP-04: Data Security, HIPAA Compliance & EMR Transmission

Document ID: SOP-04
Department: IT & Privacy Compliance
Approved By: Robert E. Beaty, Founder

Effective Date: August 2026
Review Cycle: Annual
Modality: Mobile Diagnostics

1.0 Purpose & Scope

1.1 Purpose: To establish strict information technology and data handling protocols ensuring that all Protected Health Information (PHI) captured during mobile diagnostic operations is secured in accordance with the Health Insurance Portability and Accountability Act (HIPAA) and the Health Information Technology for Economic and Clinical Health (HITECH) Act.

1.2 Scope: This protocol applies to all field testing hardware, cloud-based middleware, AWS S3 storage buckets, and transmission pathways utilized by DirectCare personnel and contracted 1099 tele-pulmonologists.

2.0 Field Hardware & Network Security

Because DirectCare operates as a mobile entity, field hardware must be heavily fortified against physical theft and network interception.

- **Device Encryption:** All field laptops and tablets utilized for the PulmOne MiniBox+ software are secured with 256-bit AES Full Disk Encryption (e.g., Windows BitLocker or macOS FileVault).
- **Authentication:** Field devices require biometric (fingerprint/facial recognition) or complex alphanumeric password authentication to unlock.
- **Independent Cellular Networks:** To prevent PHI exposure on unsecured networks, DirectCare personnel are strictly prohibited from connecting field devices to public or host-clinic "Guest" Wi-Fi networks. All data transmission occurs exclusively over DirectCare's dedicated, encrypted 5G/LTE cellular connections.
- **Remote Wipe:** All mobile devices are enrolled in Mobile Device Management (MDM) software capable of executing an immediate remote data wipe in the event a device is lost or stolen.

3.0 Cloud Transmission & Tele-Overread Workflow

The transmission of diagnostic data from the rural clinic to the reviewing specialist is governed by secure, end-to-end encryption protocols.

1. **Data Upload:** Upon completion of the PFT suite, the raw aerodynamic data and flow-volume loops are encrypted in transit (TLS 1.2 or higher) and transmitted to the secure DirectCare cloud portal.
2. **AWS S3 Secure Storage:** Report PDFs and raw data files are stored at rest using 256-bit AES encryption within dedicated, HIPAA-compliant Amazon Web Services (AWS S3) buckets.
3. **Physician Access:** Contracted board-certified pulmonologists access the diagnostic queue via a secure web portal utilizing multi-factor authentication (MFA) and JSON Web Token (JWT) session management.
4. **Electronic Signature:** The reviewing pulmonologist appends their clinical interpretation and securely executes an electronic signature, locking the PDF from further unauthorized modifications.

4.0 Final EMR Delivery & Custodianship

DirectCare Pulmonary Diagnostics functions as an ancillary diagnostic service provider. The partner primary care clinic remains the primary medical home and legal custodian of the patient's medical record.

- **Transmission to Host Clinic:** Within 24 to 48 hours of test completion, the finalized, electronically signed diagnostic report is delivered to the host clinic's Electronic Medical Record (EMR) system.
- **Delivery Methods:** Delivery is executed via frictionless, HIPAA-compliant pathways pre-determined with the host clinic's office manager. Approved methods include:
 - Secure Direct Messaging (HIPAA Direct Email).
 - Encrypted Cloud Fax routing (e.g., Updox, Sfax).
 - Authorized download from the encrypted DirectCare B2B web portal.
- **Data Retention Limit:** DirectCare does not serve as the permanent repository for patient medical records. Following successful transmission and verification of receipt by the partner clinic, data retained on DirectCare servers is subject to automated archival and secure purging in accordance with state retention statutes.

5.0 Business Associate Agreements (BAAs)

To legally operate within the HIPAA framework, formal Business Associate Agreements (BAAs) are mandatorily executed and maintained across the entire chain of data custody:

- **With Host Clinics:** DirectCare executes a BAA with every partner clinic, legally outlining DirectCare's responsibilities as a Business Associate handling PHI on behalf of the Covered Entity (the clinic).

- **With 1099 Physicians:** All contracted tele-pulmonologists must sign an Independent Contractor Agreement and a BAA prior to being granted access to the secure reading portal.
- **With Technology Vendors:** DirectCare maintains active BAAs with all underlying cloud infrastructure providers, including Amazon Web Services (AWS) and its secure hosting platforms.

END OF STANDARD OPERATING PROCEDURE SOP-04